

U

O

W

CSIT305 Emerging Information Technologies and their Applications



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

Blockchains and Smart Contracts



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

Subject Logistics

- (1) Advanced Database Overview
- (2) Spatial Data and Computing
- (3) Graph Data and Computing
- (4) Text Data and Processing

Multi-Modal Database



- (1) AI4SE: artificial intelligence for software engineering
- (2) Software Engineering in Cloud Computing I
- (3) Software Engineering in Cloud Computing II

Software



- (1) IoT and Edge Computing
- (2) Digital Twin Technology
- (3) Blockchains and Smart Contracts
- (4) Emerging Cyber-Attacks

Networking



Outline

- Blockchains
- Smart Contracts
- Applications



Long-standing Problems

- Double-spending: data can be copied in digital systems
- Centralisation & single point of failure
- Trust deficit between parties
- Lack of transparency
- Fraud & data tampering
- Slow & expensive cross-border transactions
- Exclusion from financial systems

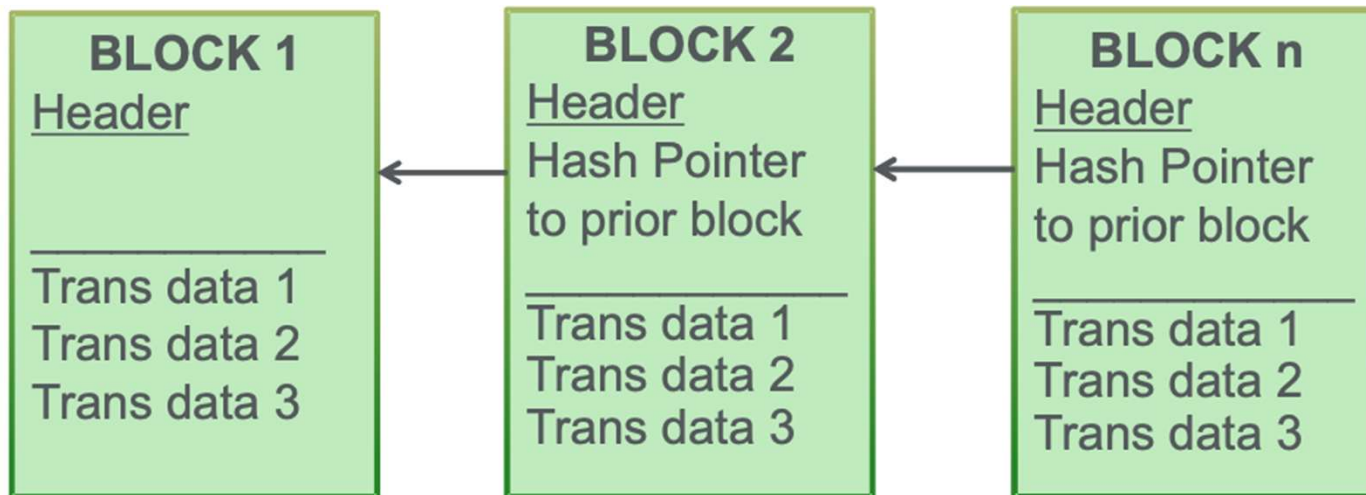
Blockchain was created to tackle **trust, security, transparency, efficiency, and inclusion** issues in digital interactions.

What is Blockchain?

- Blockchain is
 - (a) a software **database** that resides on a computer network that
 - (b) permits all parties within the network to enter into and record **transactions** and other **data** in a linked series of cells
 - (c) using a **decentralized** and **shared digital ledger**
 - (d) once entered, the data is **immutable** and **cannot be changed**.
- In a pure blockchain there is no central authority who decides what goes on the blockchain or holds the only authorized copy of the transaction.

Blockchain Technology Basics

- The blockchain holds data on a computer network in a series of cells ["**blocks**"] that are **chained** together in chronological order.



Blockchain Technology Basics

- Each block is connected to the **prior** block by means of a link known as a cryptographic “**hash**”. The hash is generated mathematically generally is 256 bits in length.
- This “hash” is how each block in the chain is **locked**.
- Blockchains are blocks of data that are securely chained to each other on a periodic (or on-demand) time basis.

Blockchain Technology Basics

- When a new blockchain is created, the first block is called the 'Genesis Block.'
 - The Genesis Block contains a list of transactions that produces a unique hash value.
 - The following chained (added) block includes a hash value of the former block.
- Therefore, the sequence of secure hash values in the blocks are what create the secure chaining effect that forms a blockchain, which starts from the Genesis Block.

Steps In A New Blockchain Transaction

- A party initiates a **new transaction** (e.g., Alice sends 1 Bitcoin to Bob) that includes the sender's address, recipient's address, and the amount.
- The transaction is digitally signed by the sender using **private key cryptography** for security. The signed transaction is broadcast to the entire blockchain network using system software.
- The computers in the blockchain network (known as "nodes") then **validate** if the transaction is valid.
- Valid transactions are grouped together into a **block** by nodes. The block contains the list of transactions, a timestamp, and a reference to the previous block.

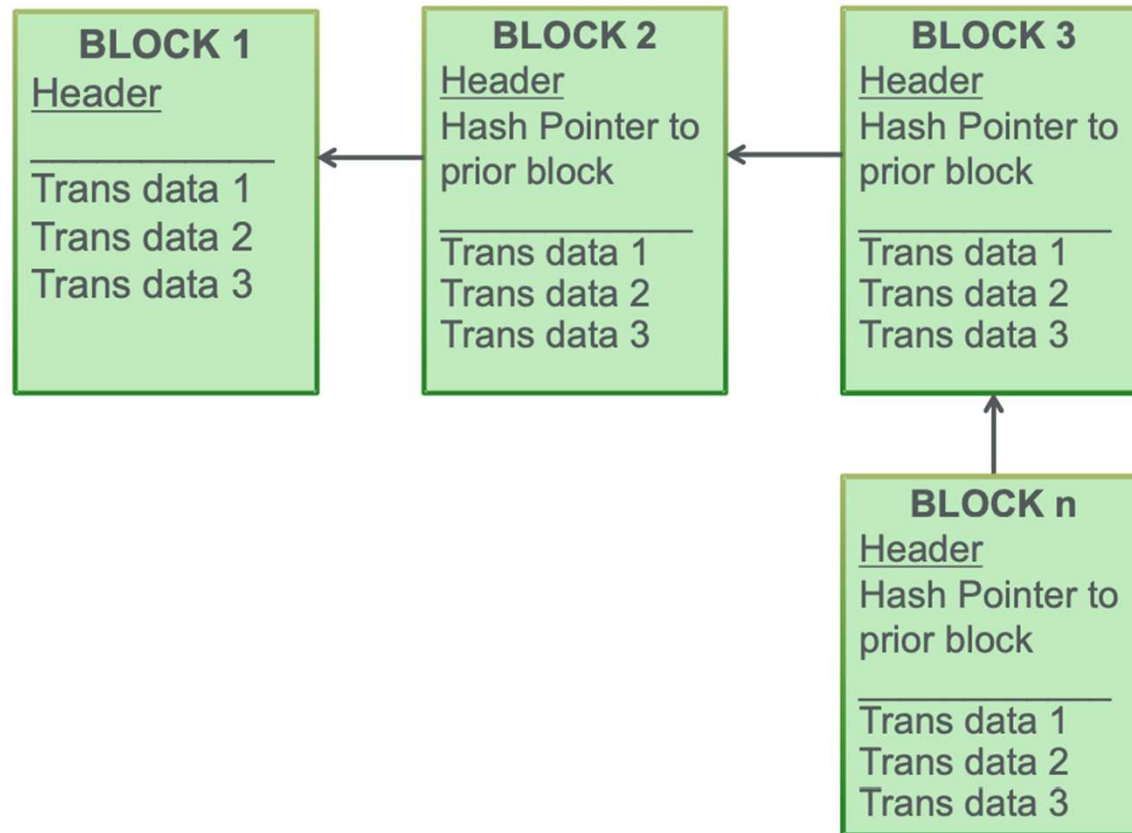
Steps In A New Blockchain Transaction

- The network agrees that the block is legitimate through a **consensus mechanism**.
 - Proof of Work (PoW) (e.g., Bitcoin): Nodes (called **miners**) compete to solve a **complex mathematical puzzle** (finding a hash below a target). The first one to solve it gets to add the block of transactions to the chain and earn a block reward.
 - Proof of Stake (PoS) (e.g., Ethereum): Nodes (called **validators**) are chosen to propose and validate blocks based on the amount of cryptocurrency they “stake”, and earn fees and rewards.

Steps In A New Blockchain Transaction

- Once consensus is reached, the block is officially added to the blockchain. The chain now has a permanent, tamper-resistant record of Alice's payment to Bob.
- Bob sees the transaction in his wallet as "confirmed." The more blocks that follow, the more secure and irreversible the transaction becomes.

Steps In A New Blockchain Transaction



Steps In A New Blockchain Transaction

- If someone tries to alter or **tamper with** the data in Block A, then the hash of that data contained in the following Block B will conflict and the change will not be accepted by the network.
- Each block in the chain thus once linked is designed to be **immutable** and not modified or deleted.
- As part of this process, the parties are issued **public and private keys** so they can conduct the transaction on the blockchain.



Steps In A New Blockchain Transaction

- Exact copies of the current blockchain ledger containing all of the transactions in the **entire** chain are **updated** and **distributed** to **every computer** in the network on a continuous basis.
- In this manner the entire blockchain database at any point in time is **shared** as the distributed ledger.

Steps In A New Blockchain Transaction

- Key Point:
 - Anyone attempting to hack into or tamper with any existing block thus would have to alter **at least a majority** of the individual copies of the current blockchain ledger then distributed to all of the members in the network – which could number in the hundreds of thousands or more.
 - This is the essential feature of the distributed ledger technology.

Main Categories of Blockchain Uses

- Cryptocurrencies & Payments
- Smart Contracts & Decentralized Applications (DApps)
- Decentralized Finance (DeFi)
- Asset Tokenization & NFTs
- Governance & Voting
- Digital Identity & Authentication
- Healthcare & Records

Why Require Blockchain?

- Double-spending: data can be copied in digital systems
 - A shared, tamper-proof ledger ensures every transaction is recorded and validated by the network, making double-spending nearly impossible.
- Centralisation & single point of failure
 - Decentralisation distributes control across many nodes, removing reliance on a single entity.
- Trust deficit between parties
 - Transactions are transparent, verifiable, and immutable.
- Lack of transparency
 - Every participant can access the same ledger, creating full visibility and auditability.
- Fraud & data tampering
 - Once data is written to the blockchain, it cannot be changed without consensus, preventing tampering.
- Slow & expensive cross-border transactions
 - Peer-to-peer transactions settle within minutes at lower costs.
- Exclusion from financial systems
 - Anyone with internet access can use cryptocurrencies and decentralized finance (DeFi) services.

Blockchain Characteristics

Table 8.1 Blockchain characteristics

Category	Blockchain characteristics
Purpose	Expandable, immutable, and secure data system used to store blocks of data periodically to support a distributed application (e.g., cryptocurrency, smart contract, etc.)
Management	Distributed management based on consensus of a majority of the blockchain users
Openness	Open (protected) data with unlimited public access (transparent)
Programming	C++, Python, R, and Java scripts are commonly used. Bitcoin (the original blockchain cryptocurrency) is programmed using C++, Python, and Java scripts. Ethereum (the original blockchain smart contract) is programmed using Solidity, which is a high-level language created for Ethereum
Data	Structured data. New data records are collected and periodically included in a new block that is chained to the blockchain
Pros	Excellent in security, reliability, immutability, transparency, and expandability
Cons	Less effective in data analysis. Low efficiency of data record keeping due to growing file size. Used for application specific data saving based on consensus management. Consensus mechanisms cannot be completely secure

Blockchain Characteristics

- Purpose
 - Blockchains were made to be expandable, immutable, and secure to store blocks of data periodically to support a specific distributed application, such as, cryptocurrency, Non-Fungible Token (NFT), smart contract, etc.
- Management
 - Blockchains use distributed management, where new data is included in a new block that is chained (added) to the blockchain if a consensus from a majority of its users can be obtained.
- Openness
 - blockchains provide protected open data with unlimited public access (transparent) using hash functions and security keys.

Blockchain Characteristics

- Programming
 - Programming for blockchains is platform dependent, however, C++, Python, R, and Java scripts are commonly used.
 - Bitcoin is the original blockchain cryptocurrency, which is programmed using C++ with functions added using Python and Java scripts.
 - Ethereum is the original smart contract blockchain platform, that is programmed using Solidity, which is a high-level language created for Ethereum, which was implemented using C++.
- Data
 - Blockchains use structured data. In blockchains, new data records are collected and periodically included in a new block that is chained to the blockchain (that includes all past data records).
 - The period of a new block chaining and the consensus procedures are based on the blockchain platform and application.

Blockchain Types

- Anyone can download the relevant software and create their own blockchain.
- There are basically three types of blockchains:
 - **Public** or "**permissionless**" blockchains, which are open to the public and are generally fully transparent. Bitcoin and most other cryptocurrencies use this type of blockchain.
 - **Hybrid** or **consortium** blockchains, which may have a large number of affiliated participants.
 - **Private** blockchains, where the shared database of transactions is limited to a certain **specified group** of participants or parties.

Blockchain Pros and Cons

- Pros
 - Blockchains are excellent in security, reliability, immutability, transparency, and expandability.
 - Blockchains are optimal for cryptocurrencies and smart contracts.
- Cons
 - Blockchains are less efficient for data analysis.
 - Blockchains have low efficiency of data record keeping due to their growing file size and chaining data records (using a sequence of hash values).

What is Smart Contract?

- **Blockchain** technology is not **only** a string of static data records stored in blocks.
- It is possible using certain versions of blockchain software to also **store executable computer programs** within the blockchain to perform functions.

What is Smart Contract?

- A smart contract is a **computer code**:
 - embedded in a **blockchain** or [eventually] other form of **decentralized ledger** that
 - incorporates all or part of a written **legal agreement** and
 - transfers digital assets or vests rights or is otherwise triggered when a set of **predefined terms and conditions** are satisfied.
- Key Points
 - The "smart contract" once written can be self-executing and autonomous, without the need for further action by the parties.
 - A form of robotics for commercial contracts.

Example

- Alice hires Bob to create a website. They want to ensure Bob gets paid **only when the work is completed**.
 - Alice deposits \$1,000 into a smart contract on the Ethereum blockchain.
 - The contract has a condition:
 - *If Bob submits the website and Alice approves it, release \$1,000 to Bob.*
 - Once Alice confirms the website is delivered, the contract automatically transfers the money to Bob.
 - If the deadline passes without approval, the money can be refunded to Alice (optional logic).

Smart Contract Background

- A smart contract is a computer program that provides both contract establishment functionality and automated execution of agreement clauses when certain contract conditions are satisfied.
- The concept of a smart contract was first proposed in 1997 by Dr. Nick Szabo at the George Washington University, who is a professor of law and a computer scientist.

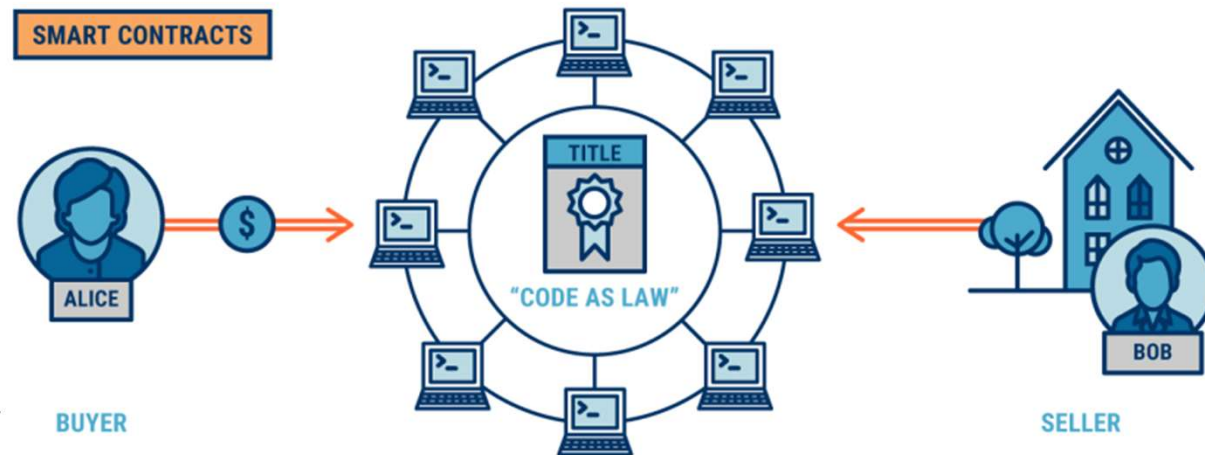
Smart Contract Background

- In 2013, the co-founder of the Bitcoin Magazine, Vitalik Buterin, released a white paper that described the need for a platform for decentralized applications.
 - The paper explained that this could be created by expanding Bitcoin and blockchain technology, which is the foundational concept of Ethereum smart contracts.
- On 2015 July 30, Vitalik Buterin and Gavin Wood released Ethereum.
 - Ethereum is the first platform to use blockchain technology to enable smart contract applications to be created and provide access to the general public.
 - Considering that smart contracts are now used everywhere, the contributions of Ethereum are significant.

Why Require Smart Contract

- Limits of current contracts
 - **“Bespoke” contracts** do not scale well.
 - **Proliferation of parties** decreases efficiencies.
 - **Verification of performance** is an issue as **number** of contracts and **locations** of performance scale.
 - **Trust** is an issue especially in cross-border transactions where **local courts** must enforce performance and payment obligations.

Example



How to Construct A Smart Contract?

- There are **competing versions of blockchain software**, similar to competing versions of computer system software such as Microsoft and Apple.
 - For example, Bitcoin has its own blockchain system for the issuance and transacting of the Bitcoin cryptocurrency as an alternative to fiat currencies such as dollars and Euros.
- The main blockchain software used for smart contracts is **Ethereum**.
 - Ethereum is a separate open-source, public, blockchain-based distributed computing platform and operating system.

How to Construct A Smart Contract?

- The difference is that unlike Bitcoin, the **Ethereum platform** also contains additional critical features:
 - **Smart contract (computer code) functionality** permitting self-executing contract terms and conditions to be embedded in the blockchain.
 - The ability to perform **computations** within the blockchain.
 - The ability to obtain **extrinsic or external data** from third parties outside of the blockchain using a function called an “**oracle**”.
 - The ability to **combine** this external data with the executable computer code within the blockchain to perform smart contract functions.
 - **Decentralized Applications (Dapps)** run on top of the platform to add functions.

How to Construct A Smart Contract?

- Step 1: Agreement
 - Two or more parties must **negotiate** a written legal contract or use a **form contract** from one of the parties or an affiliation group containing their agreement.
 - The contract must include specific transactions or other rights and obligations that vest or are executed upon **specified sets** of conditions.

How to Construct A Smart Contract?

- Step 2: Conditions
 - The parties **must set**
 - **All of the conditions** to be automated under their agreement.
 - All **permutations** of each of those conditions.
 - The **intended result or instruction** in each case.
 - The set conditions can be **internal** to the contract:
 - The **manufacture or shipping or delivery** of a product.
 - A schedule of **due dates** for payments.
 - **Expiration** of inspection rights or warranties.
 - A form of **deliverable** or notice by a party.

How to Construct A Smart Contract?

- Step 2: Conditions
 - The set conditions can be **external** to the contract:
 - Acts or omissions of **third parties**
 - Accidents or weather or climate events or other **acts of God**
 - Other events of **force majeure**
 - Financial or product **market triggers**
 - **Changes** in legal or financial status

How to Construct A Smart Contract?

- Step 3: Coding
 - The smart part of a contract requires the writing of a **computer program or code** which incorporates all of the set conditions and results, so that the contract will automatically be performed when those conditions are triggered.
 - In Ethereum the main programming language for writing smart contracts is **Solidity**.
- Key Point
 - A smart contract therefore always has **two versions**: the human language version and the machine code version.

How to Construct A Smart Contract?

Written Contract:

- Human language
- All parts of agreement
- Freely modifiable in writing by the parties.
- Subject to interpretation

Smart Version:

- Machine computer code
- Only transactions to be automated
- Embedded into blockchain or other ledger
- Cannot be changed
- only added to.

How to Construct A Smart Contract?

- Step 4: Blockchain
 - The smart contract code is **published** to the blockchain or other decentralized ledger network by the parties.
 - The smart contract code is **verified** and then "written" into a block in the blockchain or other ledger.
 - The parties are issued **public and private keys** so they can conduct the transaction on the blockchain.

How to Construct A Smart Contract?

- Step 5: Execute
 - **Execution** of the transaction is triggered:
 - by a message sent by a party validated
 - by its **private key** or
 - by the **objective satisfaction** of external or other **events or conditions** coded into the program.
 - The transaction [such as transfer of funds or title] is **automatically performed** pursuant to the smart contract code.

How to Construct A Smart Contract?

- Step 6: Recording
 - The **completed transaction** [for example: sale of property; payment of royalties; delivery of shipment] is verified and written into a new block in the chain.
 - All of the computers [nodes] which are part of the relevant network are then distributed **updated copies of the ledger** which show that the transaction is completed.

Smart Contracts Pros and Cons

- Pros
 - Provide a way to conduct transactions in a creditable and reliable method without involving legal arbitration or a third-party organization like a bank or credit card company.
 - Because the smart contract computer program can be checked by all contracting entities before it is agreed upon (i.e., digitally signed), the conditions of the smart contract are transparent and immutable. For this purpose, smart contracts use blockchains to store data, conduct consensuses, maintain transparency and immutability while minimizing the influence of external administration and management.
 - Due to using blockchains, smart contracts are considered to be more transparent and reliable (due to immutability) than regular arbitrated contracts.
 - Details of the contract terms and what will happen when contracted clauses are satisfied are easy to understand because they are clearly revealed in the computer program that can be checked before the (digital) signing of the contract.

Smart Contracts Pros and Cons

- Pros

- Compared to this, smart contracts can be clearly understood by anyone that can read the smart contract program and the expected results can be tested and computer simulated based on various cases before the (digital) signing of the contract.
 - In many cases, regular arbitrated contracts can only be understood by lawyers and take significant time and legal fees to draw up a contract. In addition, in many cases the lawyers will not agree on the meaning or interpretation of established contract terms, in which arbitration, lawsuits, and court rulings are needed.
 - This significantly helps to reduce the misunderstanding of the contracting parties. This is why almost all cryptocurrencies use smart contracts for establishment, which helps investors, users, and miners.

Smart Contracts Pros and Cons

- Cons
 - Smart contracts are vulnerable to cyber-attacks including various types of ransomware attacks.
 - If a user's login ID and password are known to a hacker then the contract itself or the compensation (e.g., cryptocurrencies) can be easily stolen (like in the 2019 Binance attack case).
 - Bugs in program code or flaws in the system operation and network protocols could be exploited by hackers.
 - This is especially true for smart contracts that have program codes open to the public (i.e., open sourced, transparent).
 - Flaws in the smart contract's program or servicing platform (or in between the program and platform) could be found by a hacker and used to exploit the smart contract (like in the 2016 DAO attack case).

Smart Contracts Pros and Cons

- Cons
 - Another difficulty is that before a contract agreement is made, an expert programmer interpretation of the smart contract would be helpful.
 - This is because a smart contract computer program cannot be accurately read and interpreted by someone that does not have expert level programming experience.
 - The assisting programmer has to be trustworthy (both personally as well as technically), which may not be easy to find as there are many smart contract platforms and programming languages used in various smart contracts.
 - Cryptocurrencies are commonly used in smart contracts, in which some cryptocurrency values are unstable.
 - This can make the Return on Investment (ROI) insignificant even though the business or activity conducted by the smart contract was successful.

Smart Contracts Applications

- Smart contracts are used in many areas, which include betting and gambling services, copyright management, cryptocurrency trading/investments, financial contract execution, gaming services, healthcare management, insurance, inter-national and domestic trade, logistics administration, non-fungible token (NFT) creation/purchasing/trading, real estate, rental services, supply chain management, etc.

Smart Contract in Insurance

- Smart automobile insurance policy
 - Track driver using sensors.
 - All data would be **continuously and permanently added** to the blockchain along with traffic citations and other external data for each policyholder.
 - The smart policy automatically (i) **increases or decreases** the **premium** based on the data and (ii) **withdraws** payment from the driver's bank account.

Smart Contract in Supply Chain

- Use of smart contract:
 - Coordination of numerous counterparties; tracking and verification of source of components; supply chain transparency under applicable law.
- Bar codes or RFID or IOT devices or other sensors would automatically identify and track each individual component and upload data to the blockchain as its status changes.

Other Smart Contract Applications

- **Stocks**

- Trading and registration of shares of corporate stock. Several states including Delaware have recently enacted statutes permitting use of blockchain as the official stock ledger.

- **Financial Instruments**

- Trading of derivatives or other financial instruments.

- **Trade Finance**

- Automated issuance of or substitution for letters of credit, guarantees and trade finance instruments.

Other Smart Contract Applications

- **Clinical Trials**

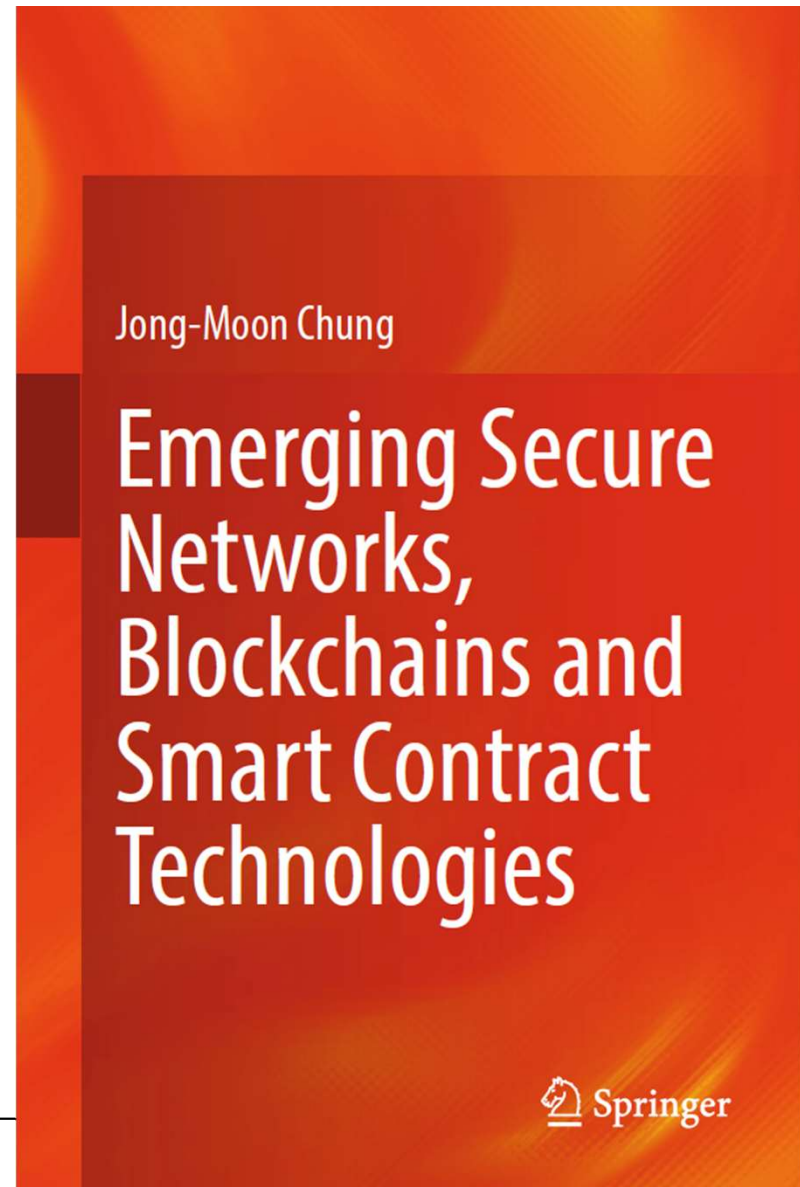
- Automated obtaining and tracking of required patient consents; standardization of patient inquiries; and secure sharing of personal medical information across institutions.

- **Scientific Research**

- Real-time secure sharing of medical or other scientific research between institutions to avoid the “silo” effect; automated nondisclosure terms to protect patent and other IP rights; automatic release of grant funds.

Reference

- Chung, J-M 2024, **Emerging Secure Networks, Blockchains and Smart Contract Technologies** First edition., Springer, Cham, Switzerland.



Emerging Cyber-Attacks



UNIVERSITY
OF WOLLONGONG
AUSTRALIA

Subject Logistics

- (1) Advanced Database Overview
- (2) Spatial Data and Computing
- (3) Graph Data and Computing
- (4) Text Data and Processing

Multi-Modal Database



- (1) AI4SE: artificial intelligence for software engineering
- (2) Software Engineering in Cloud Computing I
- (3) Software Engineering in Cloud Computing II

Software



- (1) IoT and Edge Computing
- (2) Digital Twin Technology
- (3) Blockchains and Smart Contracts
- (4) Emerging Cyber-Attacks

Networking



Outline

- Recent Trends in Advanced Cyber-Attacks
- Ransomware
- Botnet Attacks Using IoT Devices
- Cryptojacking on Blockchain Cryptocurrencies
- Cyber-Attack Defense Systems

Why Have Cyber-Attacks?

- The reliance on IT networks and databases is truly significant, as AI and big data systems need to process the data and exchange information to properly support the manufacturing and public service facilities as well as various consumer electronic services.
 - Therefore, it is evident that network security, big data processing, and database protection is critical to maintain.
 - This is more important than ever because the number of cyber-attacks has increased a lot and the level of malicious abuse to its victims (e.g., businesses, governments, and users) is significant.
- The evolution of AI technologies (including machine learning, deep learning, and reinforcement learning) also made cyber-attack systems highly intelligent, autonomous, faster, and adaptive.

Cyber-attack Types

- Based on IBM's 'X-Force Threat Intelligence Index 2022' report, the leading cyber-attack types in 2021 are presented.

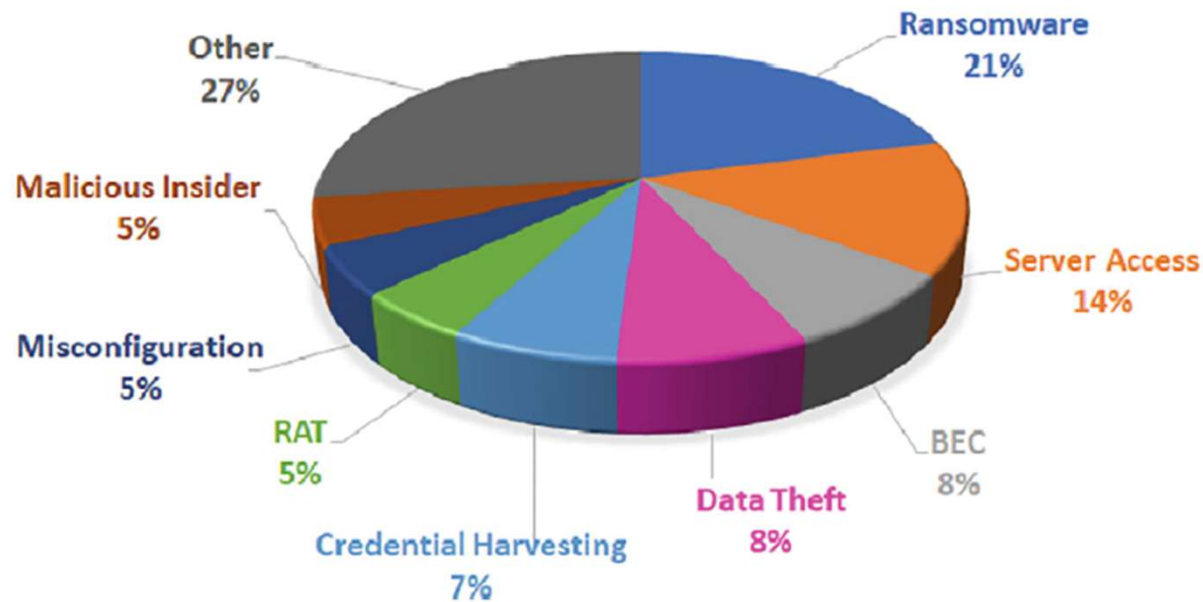
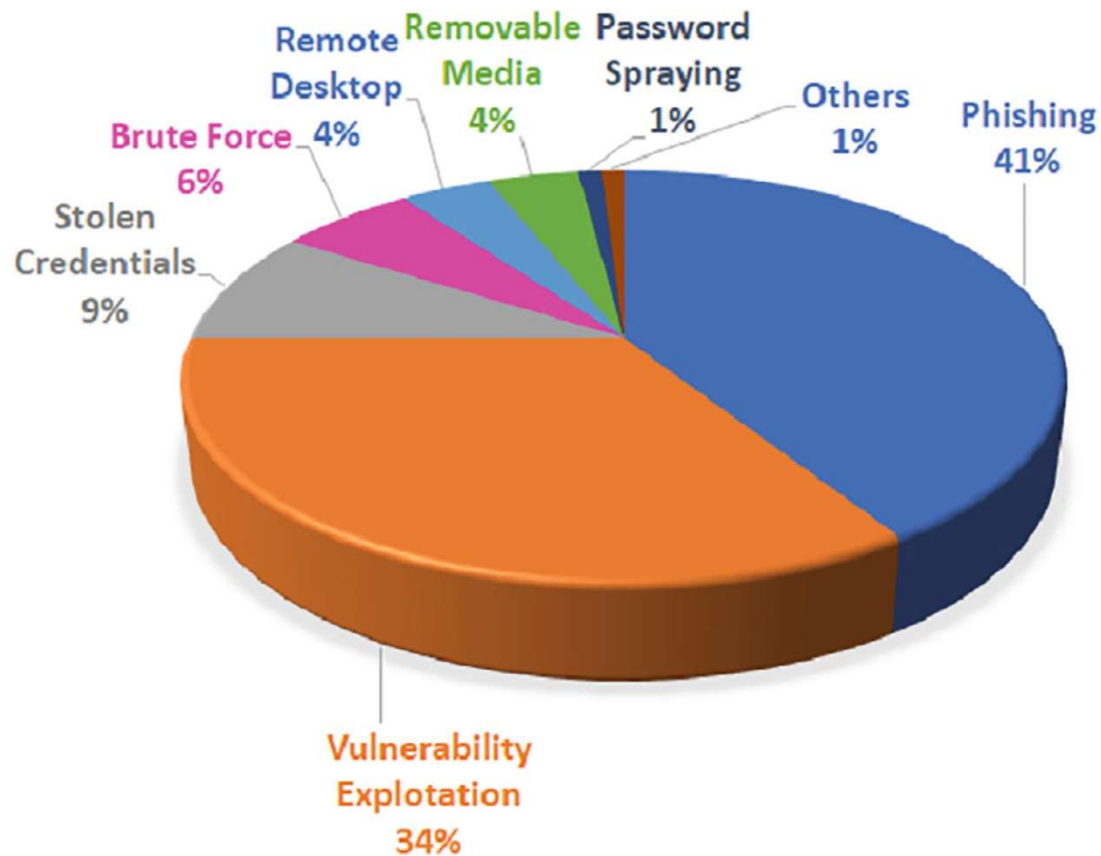
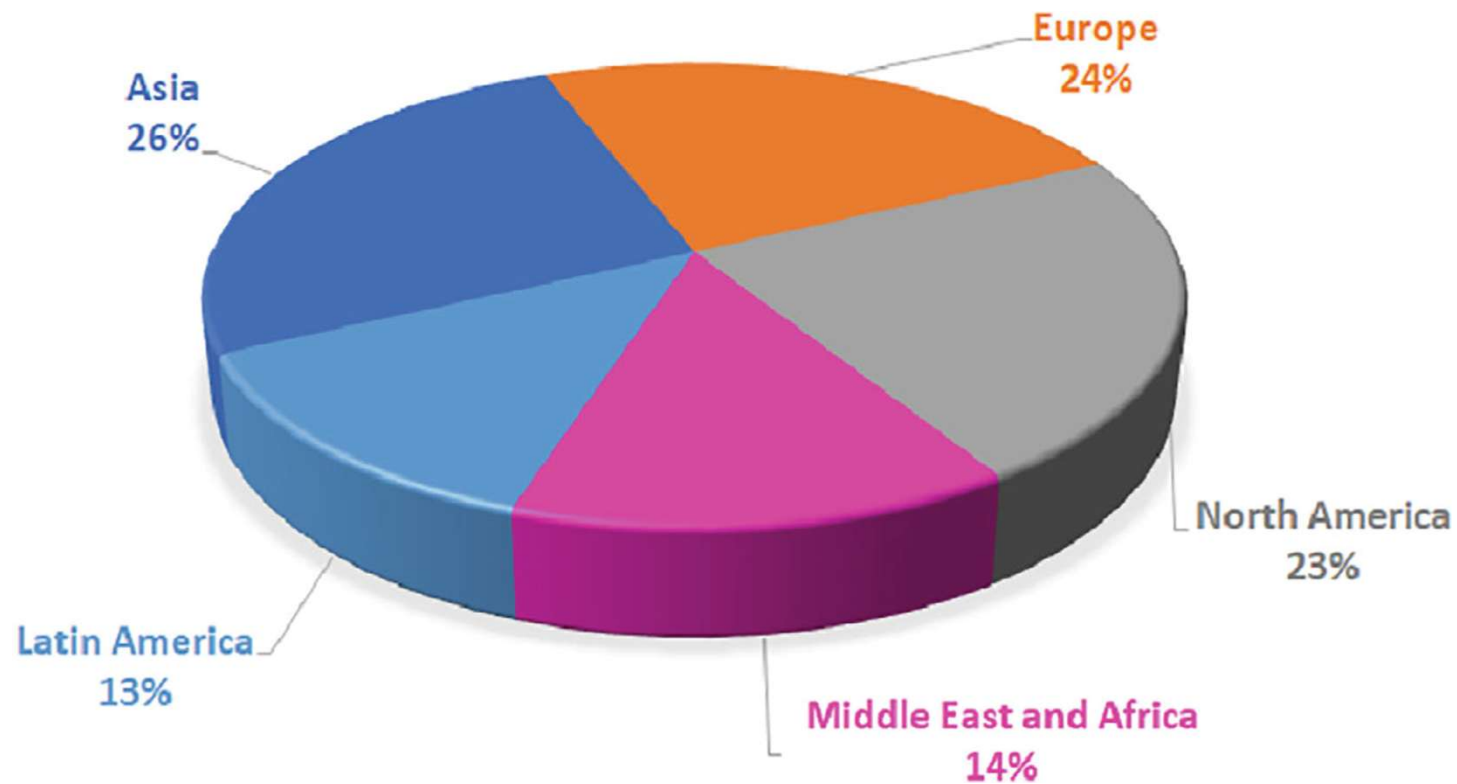


Fig. 1.1 Leading cyber-attack types in 2021

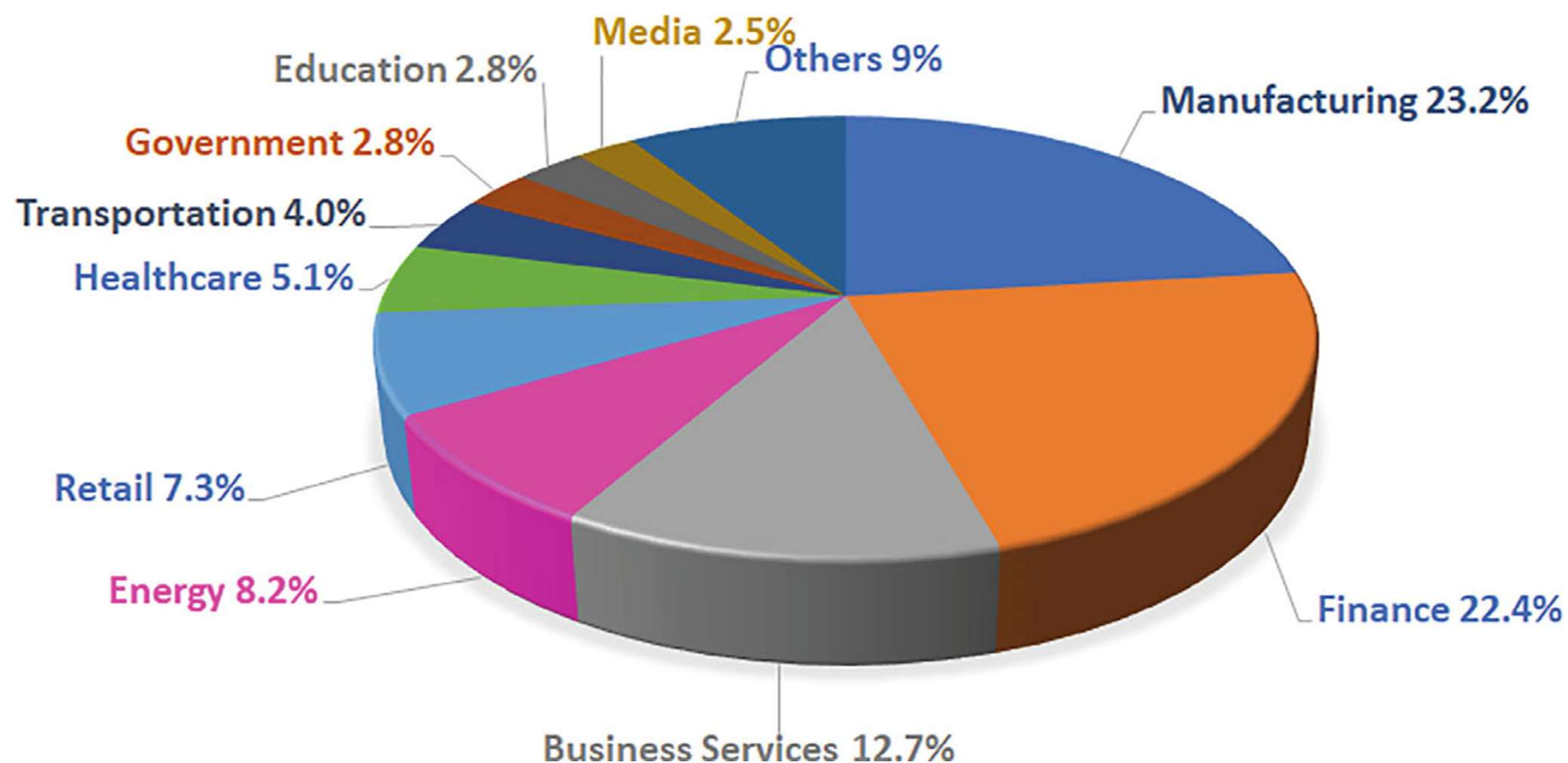
Initial Access Infection Techniques



Global Distributions of Cyber-Attacks



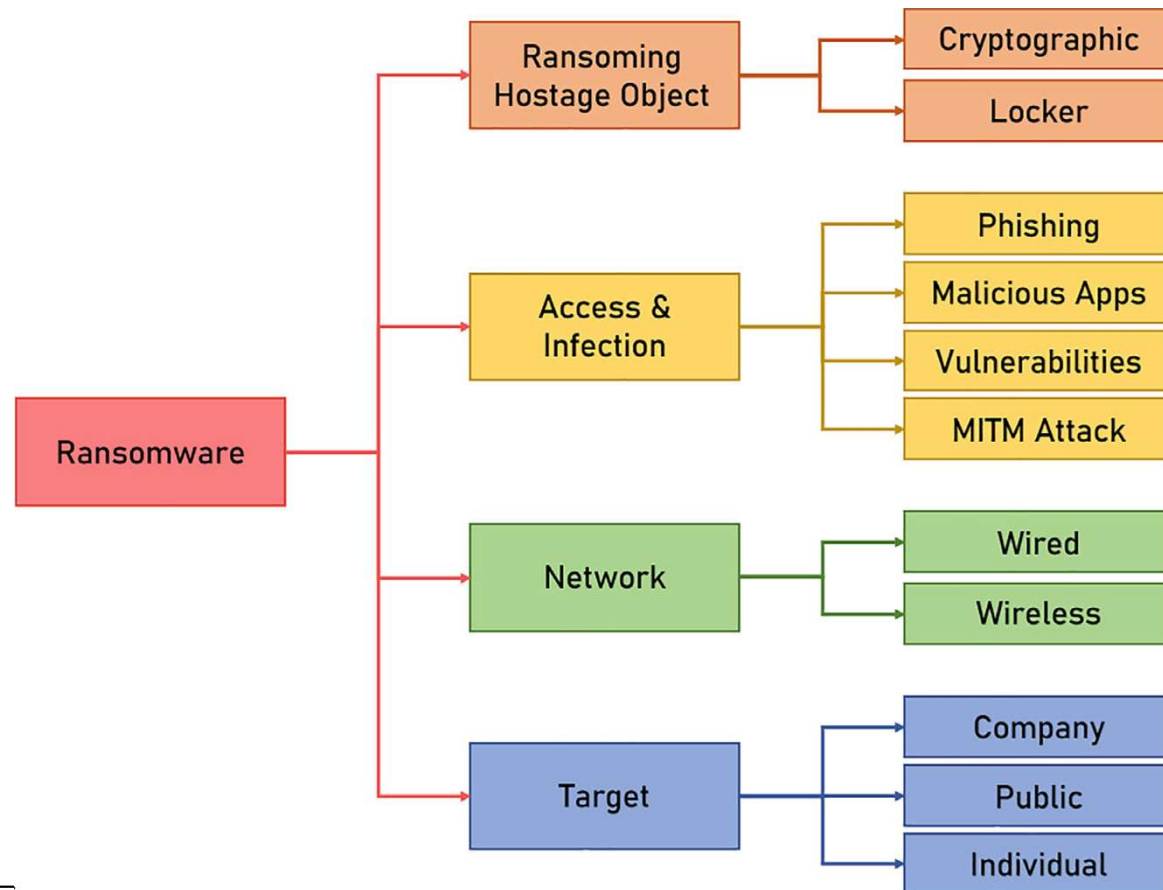
Industry Types that Receive the Most Cyber-Attacks



Ransomware

- The first ransomware emerged in 1989, when Personal Computers (PCs) first came out and the Internet was in its early stages.
 - The AIDS Trojan malware had gotten on to the 20,000 floppy disks that were mailed to the AIDS conference participants, which is how the infection began.
 - The AIDS Trojan malware would use symmetric encryption on the 'c:' drive file names and then requested for a ransom payment.
- In 2020, the Corona ransomware emerged and attacked hospitals by ransoming patient health records.
 - As this was during the COVID-19 global pandemic, the Corona ransomware had a horrific influence.

Ransomware Classification



Ransomware Classification

- **Ransoming object**, which may be files of the platform system.
 - In Cryptographic ransomware, the attacker will encrypt files and use this as a hostage until a ransom payment is made.
 - In Locker ransomware, the attacker will lock the access system, screen, browser, etc. (but may not encrypt the files) until a ransom payment is made.

Ransomware Classification

- **Infection** methods could be another way to classify ransomware.
 - Phishing is the most common malware infection method, in which e-mails, phone calls, Short Message(ing) Service (SMS), Instant Messenger (IM), Social Networking Service (SNS), etc. are used.
 - Malicious apps such as advertisements or infected websites could be used as camouflaged sources that trigger malware downloads into a system.
 - Vulnerabilities in the OS and network protocol can be exploited until a weak point is detected and used to penetrate the systems to plant ransomware malware.
 - Man-In-The-Middle (MITM) techniques could be used to obtain system login information such that the attacker can access the system and take control over the system's platform and files.

Ransomware Classification

- **Network type of wired and wireless**

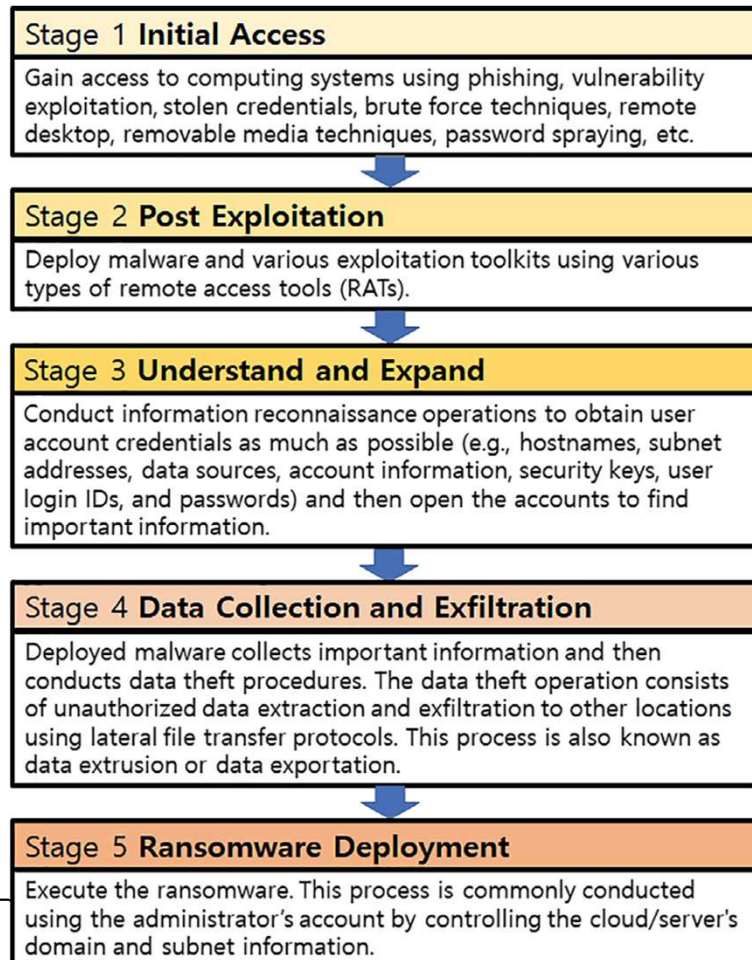
- Wired networks are connected through pre-installed servers and routers located at fixed locations that connect users to the Internet and intranet servicing companies, public facilities, home appliances, the military, etc.
- Wireless networks include smartphones, portable computers (e.g., laptops, tablets, pads, slates, and smart devices), autonomous vehicles, drones, as well as various Internet of Thing (IoT) systems.

Ransomware Classification

- **The ransomware target**

- Many companies have been ransomware victims, which includes manufacturing, financial, sales, retail, logistics, etc.
- Public facilities and infrastructures have been targets.
 - Such examples include the Corona ransomware that attacked hospitals during the COVID-19 pandemic in 2020 and the Colonial Pipeline ransomware attack on the southeastern area of the United States that occurred in 2021.
- Individuals are always targets for ransomware attacks, as defense mechanisms and retaliation methods are very limited, making individuals easy victims.

Ransomware Attacks Procedures



Ransomware Attacks Procedures

- Ransomware attacks can be classified into 5 stages, based on IBM's 'X-Force Threat Intelligence Index 2022' report.
- Stage 1: Initial Access
 - The top ranked methods used to gain initial access for a cyber-attack is phishing, vulnerability exploitation, stolen credentials, brute force techniques, remote desktop, removable media, and password spraying.
- Stage 2: Post Exploitation, which depends on the stage 1 initial access type established.
 - If a remote desktop breach was established, the stage 2 post exploitation process may include deployment of post exploitation toolkits like a Remote Access Tool (RAT) and deployment of malware, which will be used in the stage 4 exfiltration process.

Ransomware Attacks Procedures

- Stage 3: Understand and Expand
 - Focus on understanding the breached system and expanding on collecting important information to use in stage 4 and stage 5 of the ransomware attack.
 - For this purpose, reconnaissance operations are conducted to collect important credentials, which include hostnames, important subnets to use, data sources, account information, security keys, user login IDs, and password information.

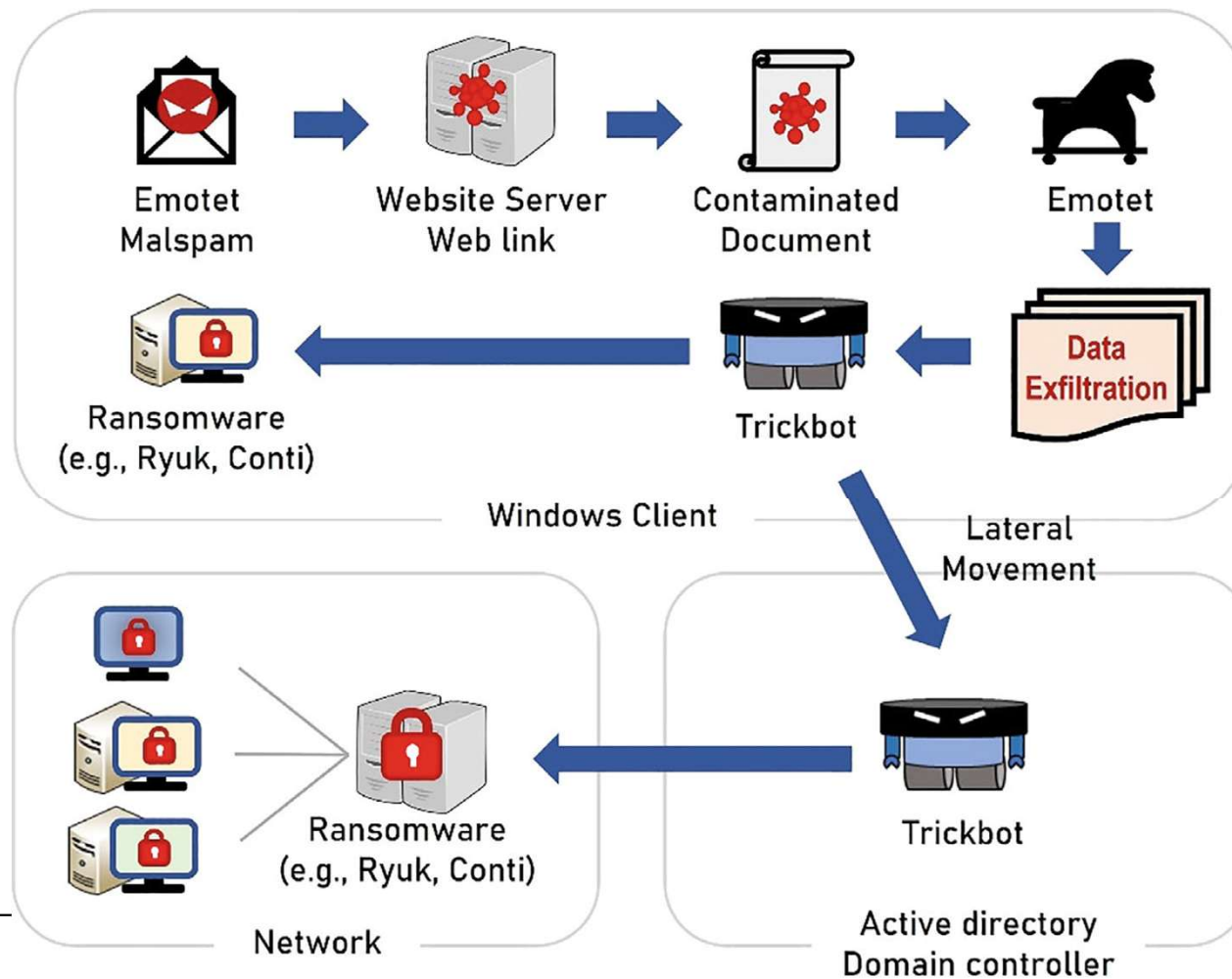
Ransomware Attacks Procedures

- Stage 4: Data Collection and Exfiltration
 - Data is collected, and the exfiltration process is conducted. Exfiltration is a process of unauthorized data extraction, which is commonly conducted using malware, which most likely was deployed in stage 2.
 - Almost all ransomware attack incidents since 2019 conduct both ransomware activity as well as data theft, resulting in 'double extortion' damage to their victims. In this stage, functions like Microsoft's Server Message Block (SMB) may be used for lateral file transfers.

Ransomware Attacks Procedures

- Stage 5: Ransomware Deployment, which is when the ransomware is deployed.
 - The ransomware is executed using the domain administrator's credentials, which most likely would have been obtained in stage 3 through the reconnaissance process of searching for essential credentials as well as domain and subnet information.

Example



Why Have Botnet Attacks?

- The number of Internet of Things (IoT) devices and size of IoT networks are growing rapidly.
 - Currently, every modernized building, office, home, facility, industry, and factory uses massive amounts of IoT devices interconnected by high-speed networks.
- The processing capability and memory size of many IoT devices are relatively small compared to Personal Computers (PCs) or servers, which is why it is very difficult to install a sophisticated security system on an IoT device.

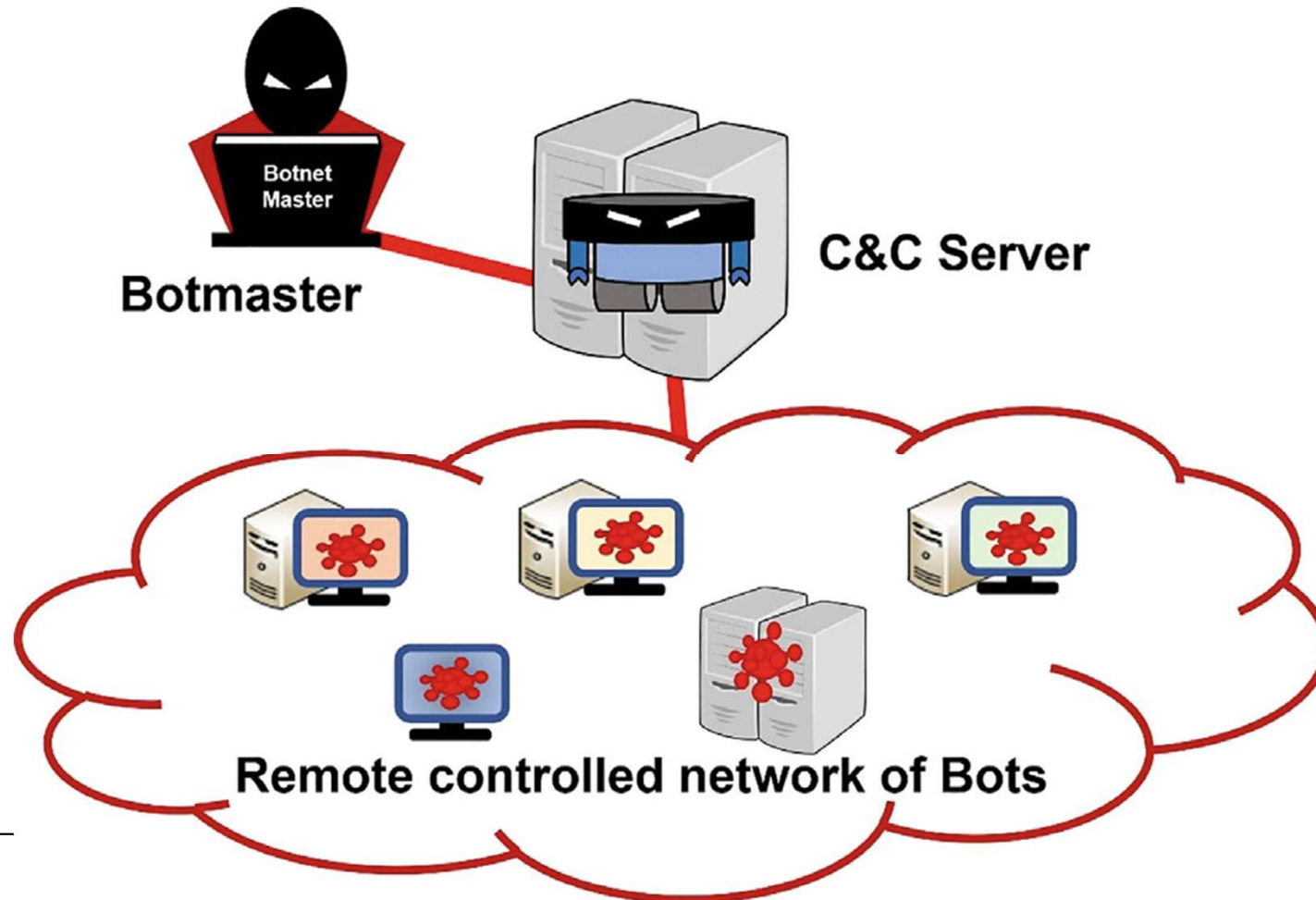
Why Have Botnet Attacks?

- Therefore, cyber-attacks to compromise an IoT device has always been a major threat. To make matters even worse, botnets can be used to compromise an IoT device, which will help to compromise additional neighboring IoT devices, and help launch a Denial of Service (DOS) or massive Distributed DoS (DDoS) attack on target servers, systems, and networks.
- Botnets commonly use a **centralized** network structure or a **decentralized** Peer-to-Peer (P2P) network structure.

Botnet Centralized Command & Control Network

- Botnet centralized Command and Control (C&C) network model, where the botnet Master controls a network of botnets through the C&C Server.
 - The IoT devices that are compromised by malware and used for botnet attacks are called ‘bots’.
 - The Botmaster can control the C&C Server to conduct various types of distributed DDoS attacks on one or multiple target servers or networks, which makes the centralized botnet structure very effective and efficient.
 - One way to defend against a centralized botnet can be to find and disable the Botmaster or C&C Server.

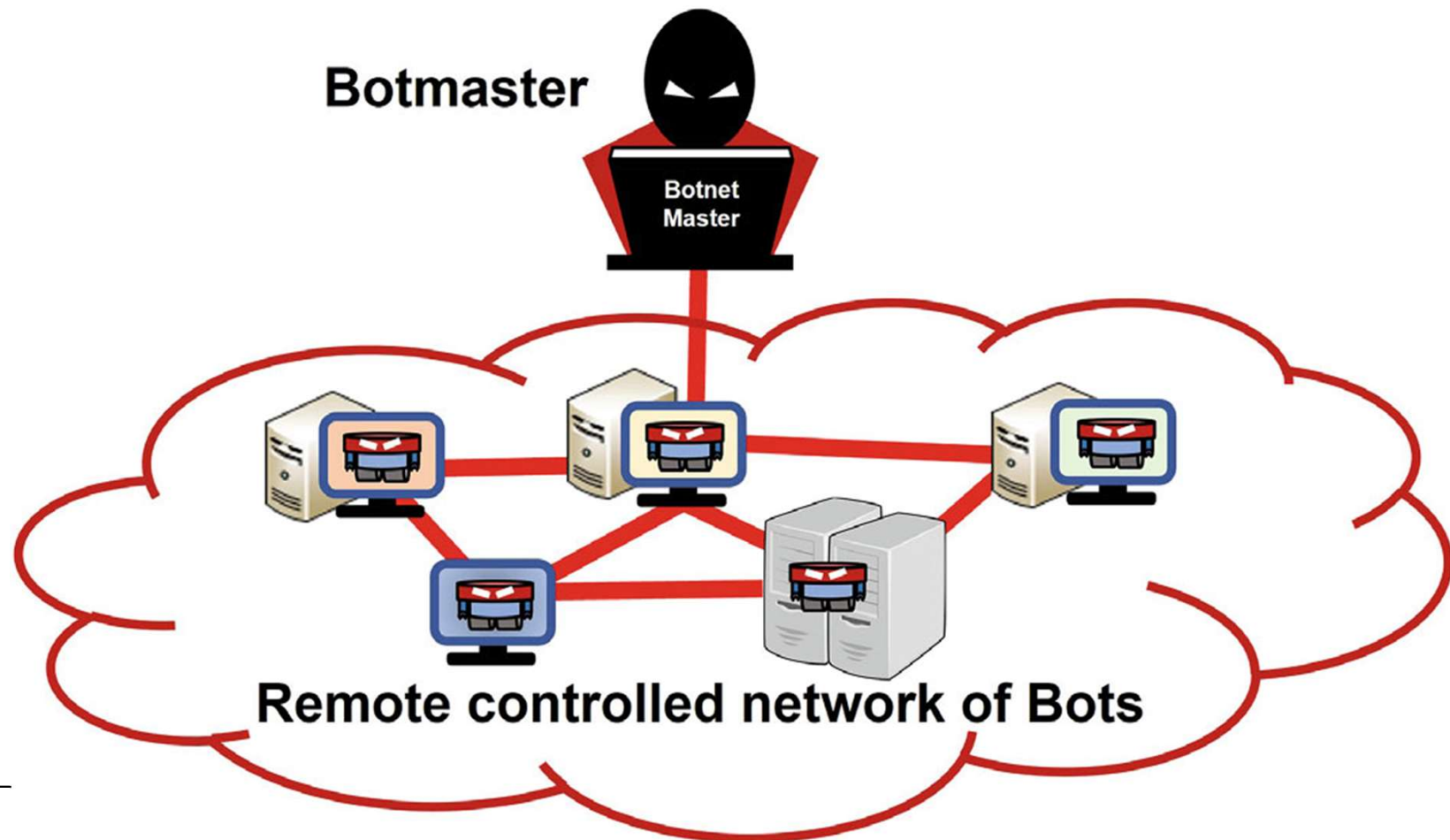
Botnet Centralized C&C Example



Botnet Decentralized Command & Control Network

- Botnet decentralized C&C network example, where the Botmaster controls the bots directly communicating with them using a P2P network communication protocol (and does not use any C&C Server).
 - It may be more difficult to defend against a decentralized botnet because there is no C&C Server that can be traced and all communication between the bots are P2P communication based.

Botnet Decentralized C&C Example



Why Have Cryptojacking?

- Due to the immense value of cryptocurrencies (e.g., Bitcoin), numerous miners around the world attempt to compute hash values to receive cryptocurrency rewards.
- Because acquiring the computational equipment and network infrastructure is so expensive, a new form of mining that takes place on a victim's computer without the owner's knowledge or authorization is called cryptojacking.
- The word 'cryptojacking' could be seen as a nickname for 'cryptocurrency reward hijacking' because the victim's computer conducts the mining work in which the computer's owner should receive the mining reward, but this reward is hijacked by the cryptojacking control entity.

Why Have Cryptojacking?

- Cryptojacking is very hard to detect, because it is made to always operate in stealth mode, so it will try to remain undetected while conducting its cryptocurrency mining operation for as long as possible.
- Cryptojacking malware has been embedded into many trusted websites, and, as a result, the cryptojacking malware spread extensively.
- Example
 - In 2017 that an Italian bank was infected with Bitcoin cryptojacking malware.
 - In 2018, it was reported that the Google advertisement programs on YouTube contained cryptojacking malware.
 - In 2018, it was also reported that the UK Government had provided a plugin program that had been contaminated with cryptojacking malware.

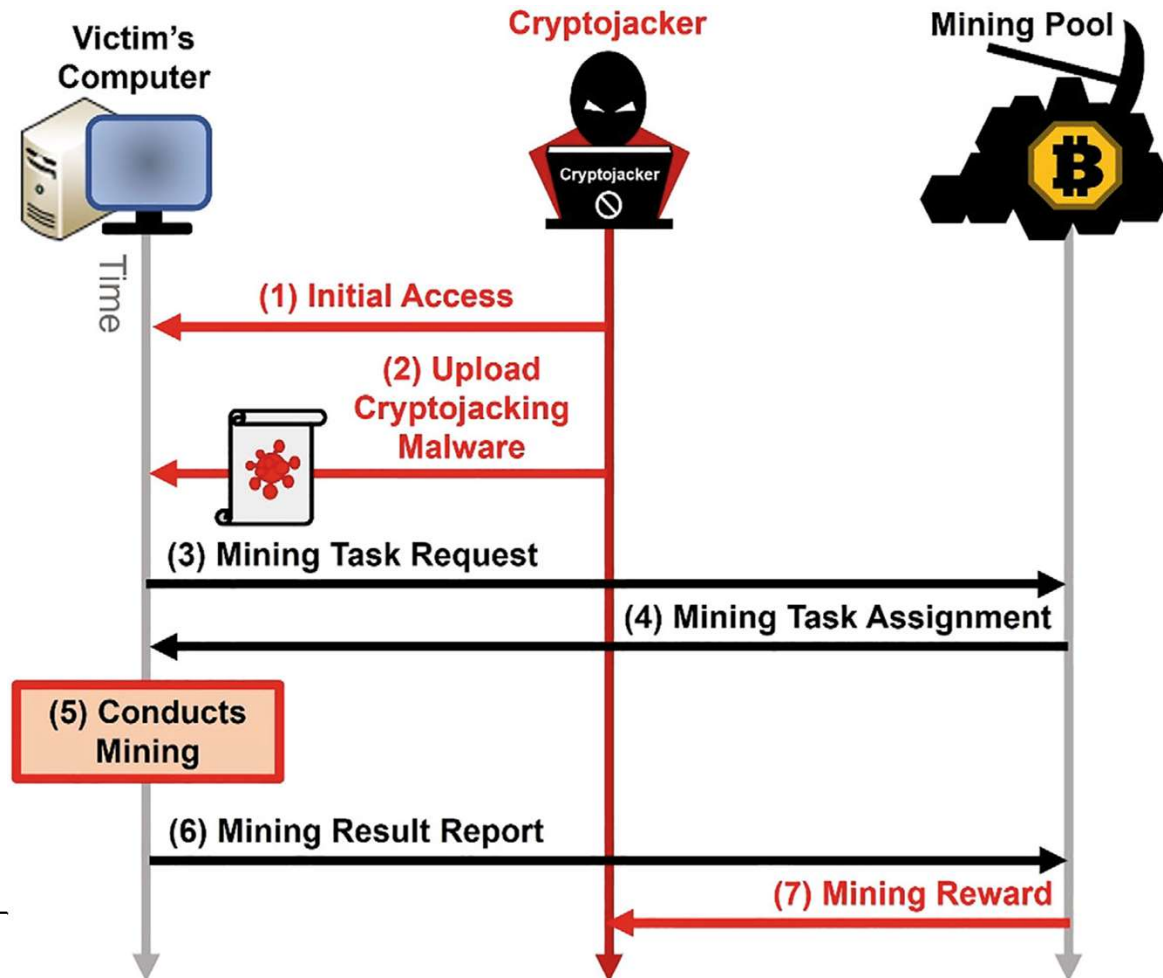
Cryptojacking Type

- There are two major types of cryptojacking:
 - Host-based cryptojacking operation
 - Website-based cryptojacking operation

Host-based Cryptojacking Operation

- The cryptojacking script owner (which will be called the 'Cryptojacker' for short) attempts to gain initial access (step 1) to a victim's computer (e.g., using phishing), and once access is obtained, the cryptojacking malware will be uploaded (step 2). Without any knowledge or authorization of the computer's owner, the victim's computer will connect to the mining pool (step 3) to receive a mining assignment (step 4). The victim's computer will conduct the mining process (step 5) and report its results to the mining pool (step 6). Any rewards issued by the mining pool will be delivered to the Cryptojacker (step 7).

Host-based Cryptojacking Operation Example



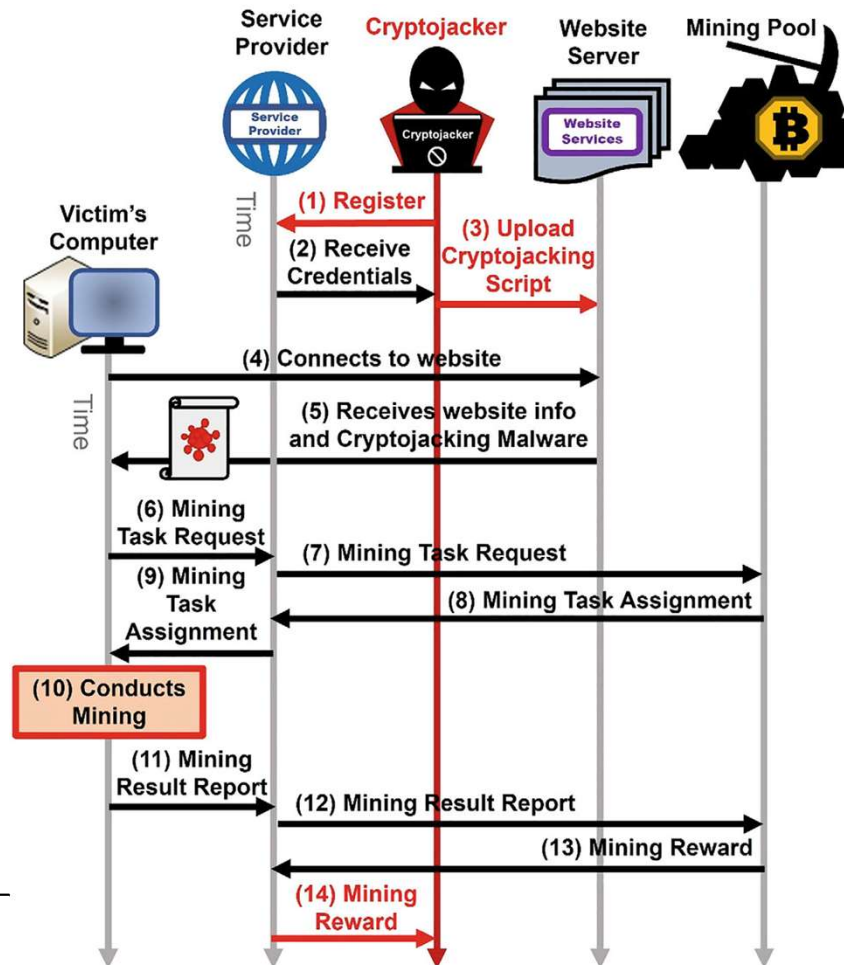
Website-based Cryptojacking Operation

- The Cryptojacker will register with a Service Provider to gain the credentials to access its website (step 1). Once the access credentials are obtained (step 2), the Crypto-jacker uploads the cryptojacking malware to the website (step 3). When the victim's computer connects to the cryptojacking contaminated website (step 4), it receives both the website information along with the hidden cryptojacking malware (step 5). Without any knowledge or authorization of the computer's owner, the victim's computer will connect to the mining pool (steps 6 and 7) to receive a mining assignment (steps 8 and 9).

Website-based Cryptojacking Operation

- Steps 6 through 9 may need to pass through the Service Provider, based on configuration of the network operation. The victim's computer will conduct the mining process (step 10) and report its results to the mining pool (steps 11 and 12). Steps 11 and 12 may need to be pass through the Service Provider, based on the configuration of the network operation. Any rewards issued by the mining pool will be delivered to the Service Provider (step 13), which will be sent to the Cryptojacker (step 14).

Website-based Cryptojacking Operation Example



Cyber-Attack Defense Systems

- The most effective cyber-attack defense systems include updated software and OSs in addition to advanced
 - Intrusion Detection System (IDS)
 - Firewalls
 - Demilitarized Zone (DMZ)
 - Transport Layer Security (TLS)
 - Wired Equivalent Privacy (WEP)
 - Secure Shell (SSH) technologies

Intrusion Detection System (IDS)

- An IDS is a system that detects malicious activity and policy violations in network devices, where the detection results are reported to the network administrator or Security Information and Event Management (SIEM) system. As the detection sensitivity is increased, the number of false alarms also increases, in which false alarms are removed by the alarm filters.
- IDS system types can be classified into Host IDS (HIDS) and Network IDS (NIDS).
 - An HIDS monitors all Internet packets sent and received, where the status snapshots are taken and compared with its former status. HIDS operates on PCs, laptops, smartphones, etc.
 - A NIDS consistently monitors to detect abnormal behavior on network systems like gateways, routers, and switches.

Intrusion Detection System (IDS)

- IDS detection schemes include Signature-based IDS and Anomaly-based IDS.
 - A Signature-based IDS scheme searches for specific intrusion patterns (e.g., malware sequences).
 - An Anomaly-based IDS scheme detects new unknown attacks (e.g., new malware behavior).

Firewalls

- Firewall is a network security monitoring and control system, that monitors all transmitted and received packets.
- Firewalls includes IDS mechanisms.
- Firewalls can be classified into network-based and host-based systems.
 - A network-based firewall is used in network gateways, routers, and switches to protect the network.
 - Host-based firewalls are used in computer OSs for endpoint (i.e., PC, smartphone) protection.

Firewalls

- As firewall technology has evolved significantly, generations of firewalls are divided as follows.
 - First generation (1G) firewalls were based on packet filtering of network addresses and ports.
 - Second generation (2G) firewalls added on stateful filters for IP packet and transport (i.e., TCP and UDP) protocol inspection in addition to 1G firewall technologies. 2G firewalls track all state changes in IPv4, IPv6, TCP, UDP, etc.
 - Third generation (3G) firewalls add various application layer (e.g., HTTP, DNS, FTP, etc.) filtering to the 2G and 1G firewall technologies. Advanced technologies included in 3G firewalls include Deep Packet Inspection (DPI), IPS, IDPS, device MAC address and reputation monitoring, as well as Web Application Firewall (WAF) technology.



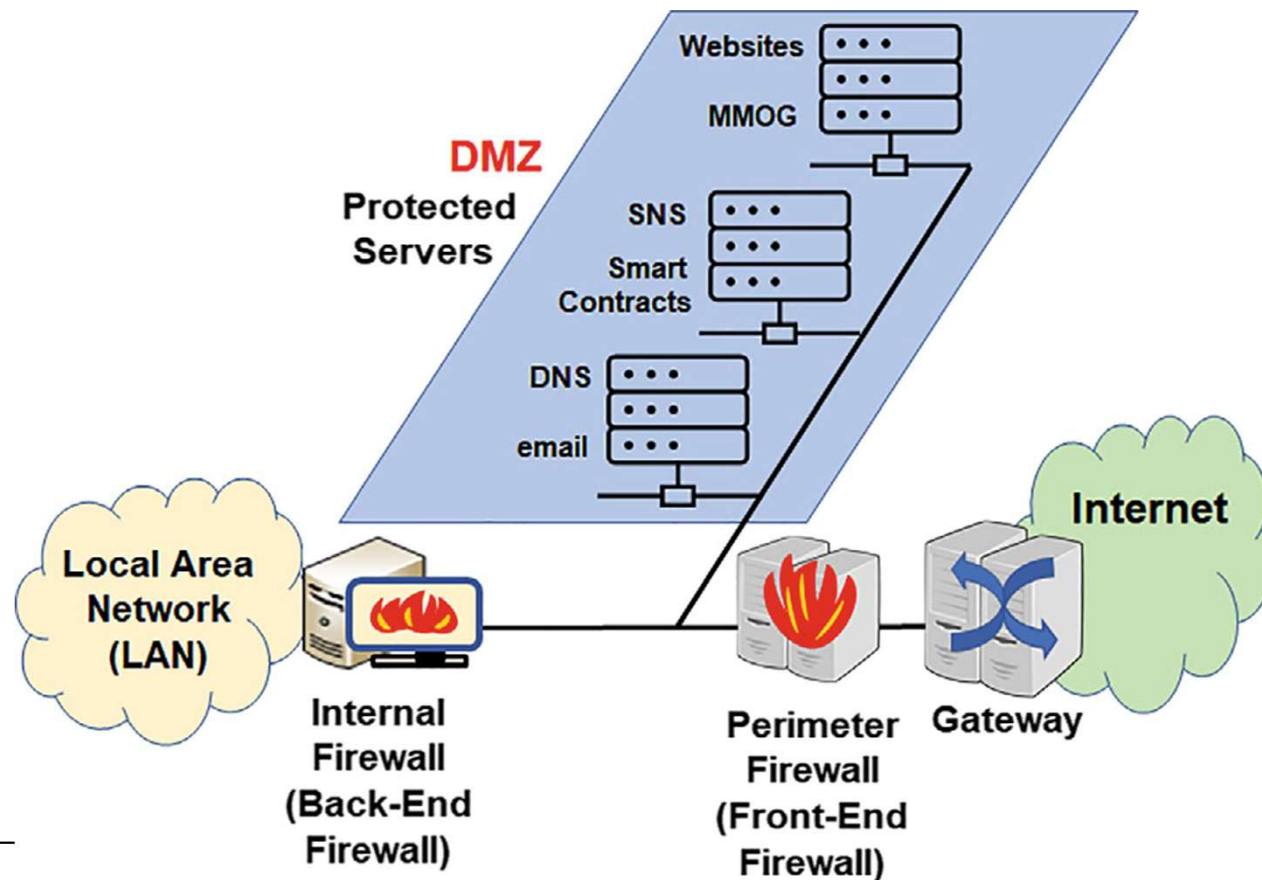
Demilitarized Zone (DMZ)

- A more advanced form of a firewall protection mechanism is to use two firewalls to form a Demilitarized Zone (DMZ).
- The term DMZ is originally used to represent an area in which there is agreement to not conduct any military operations (e.g., like the DMZ between North Korea and South Korea).
- In network security, a DMZ is a physical and/or logical network subarea that is between the external network (e.g., Internet) and internal network (e.g., local area network (LAN)), which is a buffer area that is used to carefully monitor all network connections before enabling entrance to the internal network, thereby significantly enhancing the security level of the internal network.

Demilitarized Zone (DMZ)

- DMZs are commonly formed using two firewalls, one at the exiting edge of the external network and one at the entrance of the internal network.
- The network area between these two firewalls becomes the DMZ. DMZs add an additional layer to protect the internal network (e.g., LAN).
 - The firewall at the exiting edge of the external network is called a 'perimeter firewall' (a.k.a., front-end firewall).
 - The firewall at the entrance of the internal network is called the 'internal firewall' (a.k.a., back-end firewall).
- There are benefits if the vendors of the perimeter firewall and internal firewall are different, as the two firewalls would not have the same vulnerabilities. However, this would increase the purchasing cost and maintenance fees.

Example - DMS using Two Firewalls



Transport Layer Security (TLS)

- TLS uses network cryptographic protocols to enable secure communications.
- TLS provides privacy and data integrity between networked applications, where symmetric cryptography is used with encryption keys generated uniquely for each connection at session setup using the TLS handshake protocol.
- Public-key cryptography is used to authenticate the identity of the communicating systems and a message authentication code is used to ensure data integrity (prevent alterations).

Wi-Fi Protected Access 2 (WPA2)

- WEP security algorithm was developed for the Institute of Electrical and Electronics Engineers (IEEE) 802.11 Wireless Local Area Networks (WLANs, a.k.a., Wi-Fi) to provide data confidentiality equivalent to the security level used in wired networks (ratified in 1997) using encryption and authentication techniques. In 2003, the Wi-Fi Alliance announced that WEP will be replaced (superseded) with Wi-Fi Protected Access (WPA).

Wi-Fi Protected Access 2 (WPA2)

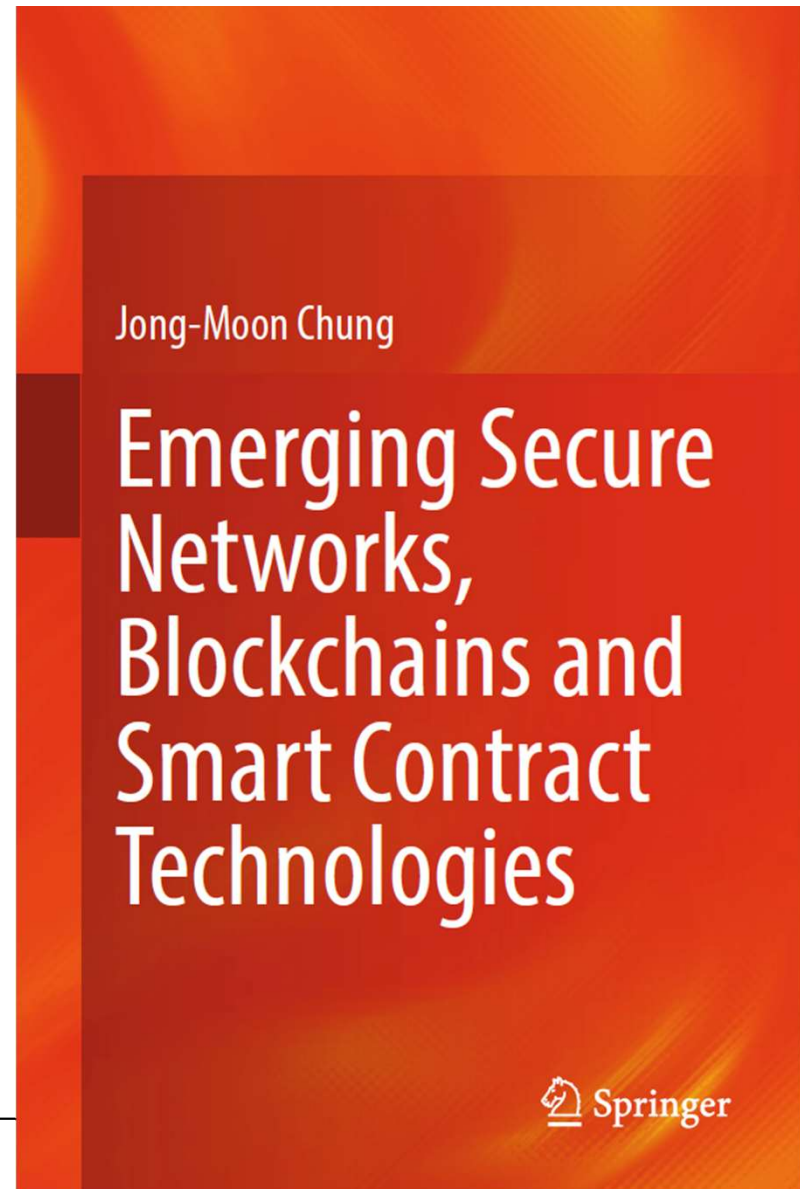
- WPA is a Wi-Fi Alliance developed (in 2003) security protocol and security certification program that uses the Temporal Key Integrity Protocol (TKIP) to dynamically generate new encryption keys for each packet.
- WPA is an improvement from WEP, but TKIP can now be broken, so new enhancements were required. WPA2 is the current WPA version commonly used, in which WPA2 certification is mandatory (since March 13, 2006) for all Wi-Fi devices.
 - WPA uses Counter Mode Cipher Block Chaining Message Authentication Code Protocol (CCMP) which is an Advanced Encryption Standard (AES) technology.
 - WPA2 includes all mandatory elements of the IEEE 802.11i standard and requires Wi-Fi Alliance testing and certification.

Secure Shell (SSH)

- SSH is a cryptography protocol to enable secure services over unsecured networks.
- SSH supported applications include remote command-line login, remote command execution, as well as various other secured network services.
- The upgraded version OpenSSH is commonly supported by all servers.

Reference

- Chung, J-M 2024, **Emerging Secure Networks, Blockchains and Smart Contract Technologies** First edition., Springer, Cham, Switzerland.



U

Thanks

O



W

UNIVERSITY
OF WOLLONGONG
AUSTRALIA